

ENGINEERING TRUST BRIEF / NOT CERTIFICATION

Keep the control record. Leave the conversation out.

A concise data-flow and responsibility summary for evaluating the v1 source contracts. Provider processing and customer-operated infrastructure remain part of the system.

Data	Handling and responsibility
Prompts and responses	Relayed transiently; excluded from routine usage/security ledgers. Allowed content reaches the provider under the customer's agreement.
Employee credentials	Authenticate to Hormuz; are not forwarded as provider credentials. Unique identities are required for useful attribution.
Provider credentials	Remain server-side in the configured environment or custody system. Do not distribute company keys to employees.
Identity and usage metadata	Bounded actor/team/model/policy/token/cost/status data. Sensitive organizational metadata, even without content.
Secret-control evidence	Rule/action/outcome/count metadata; no matched secret value or raw request material.
Infrastructure logs/backups	Operator-owned. Disable body logging; restrict access; define retention, deletion and backup protection.

Coverage is the governed model-request path

Client to Hormuz identity/policy/secret/budget checks to allowed provider call. A denial must not make that upstream call. Shell commands, MCP servers, browser/Git traffic and bypassed requests are outside the gateway's coverage.

Sources: [Architecture](#) · [Audit](#) · [Clients](#)

TRUST / CAPABILITIES, LIMITS, AND REVIEW

Review the gaps in your environment.

Implemented, with specific boundaries

Identity: OIDC JWT verification, with issuer/audience/expiry/signature checks and explicit subject mapping. Issuance/refresh remain with identity tooling. No native Hormuz browser login, refresh custody or session-revocation endpoint.

Secrets: deterministic redact, deny or off modes—not complete semantic DLP. Custody-lifecycle approvals are separate from inference; no per-inference human-approval workflow is claimed.

Usage: captured gateway traffic in the current UTC month, with configured-rate-card cost estimates—not complete provider-account coverage or reconciled invoices.

Maturity: v1.0.0 source CLI/policy/evidence contracts; separate v0.1.3 linux/amd64 signed OCI reference. Reference evidence does not certify your deployment.

Questions to resolve before production traffic

Who owns TLS/ingress and bypass controls? How are tokens issued, refreshed and revoked? Where are provider keys held? Who has administrative access? What are metadata/log/backup retention and deletion rules? Which migration, rollback, HA, capacity and recovery checks pass here? What remains for independent security review and provider/contract review?

Inspect synthetic evidence

The [demo evidence pack](#) contains four usage events and one secret-control event from a separate provider-free run. Product schema and forbidden-content checks passed before export. These are synthetic records, not a customer case study or human onboarding result.

Report a vulnerability privately

Follow [SECURITY.md](#). Do not submit sensitive material through public issues or the marketing form. General evaluation contact: **Mehrdad Zaker**, zaker.mehrdad@gmail.com.

Sources: [Full trust brief](#) · [OIDC](#) · [Secret controls](#) · [Usage](#) · [Operations](#)